



Análise do Protocolo Kerberos

Estudo sobre autenticação e segurança em sistemas distribuídos, com foco em Kerbero.

Introdução: Contexto e Problema

- Segurança da informação é pilar dos sistemas distribuídos: abertura e conectividade trazem vulnerabilidades como sniffing e spoofing.
- O desafio central é autenticar clientes sem expor senhas em canais inseguros e reduzir repetições de autenticação que prejudicam usabilidade e segurança.



Por que Kerberos?

Kerberos oferece autenticação forte em redes inseguras usando criptografia simétrica e uma Terceira Parte Confiável (TTP). Permite provar identidade sem transmitir senhas em claro, garantindo integridade e confidencialidade das sessões.



Objetivo do Artigo

Analisar arquitetura de segurança do Kerberos: conceitos de criptografia e canais seguros, fluxo de obtenção de tickets, mitigação de replay attacks e estudo de caso no Active Directory.



2 - Conceitos: Canais Seguros

Um canal seguro garante:

- confidencialidade (só quem deve ler, lê);
- integridade (a mensagem não foi alterada no caminho);
- autenticação (garantia de que as partes são quem dizem ser).

Esses são fundamentos para projetar segurança em sistemas distribuídos.



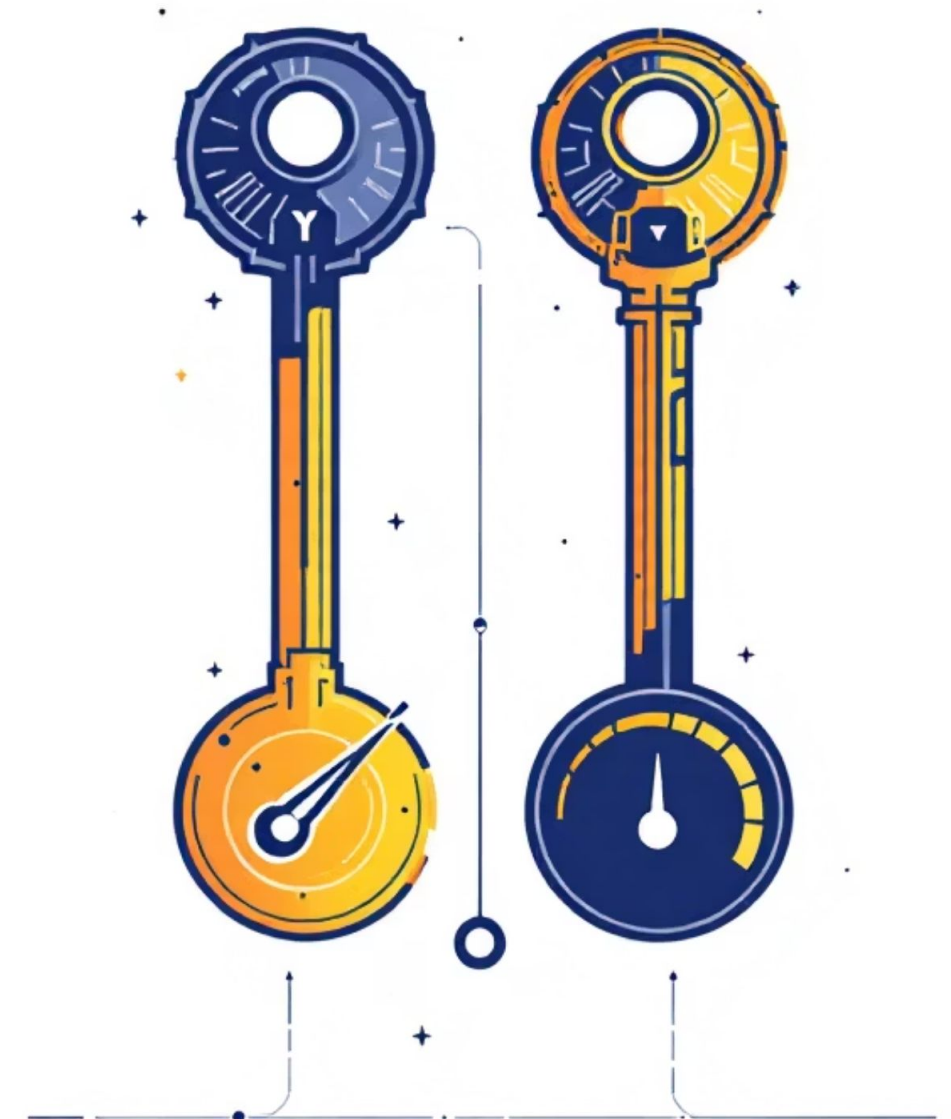
2.1 Criptografia: Tipos e Trade-offs

Criptografia Assimétrica

Par de chaves pública/privada;
resolve distribuição e
assinaturas, mas é
computacionalmente cara.

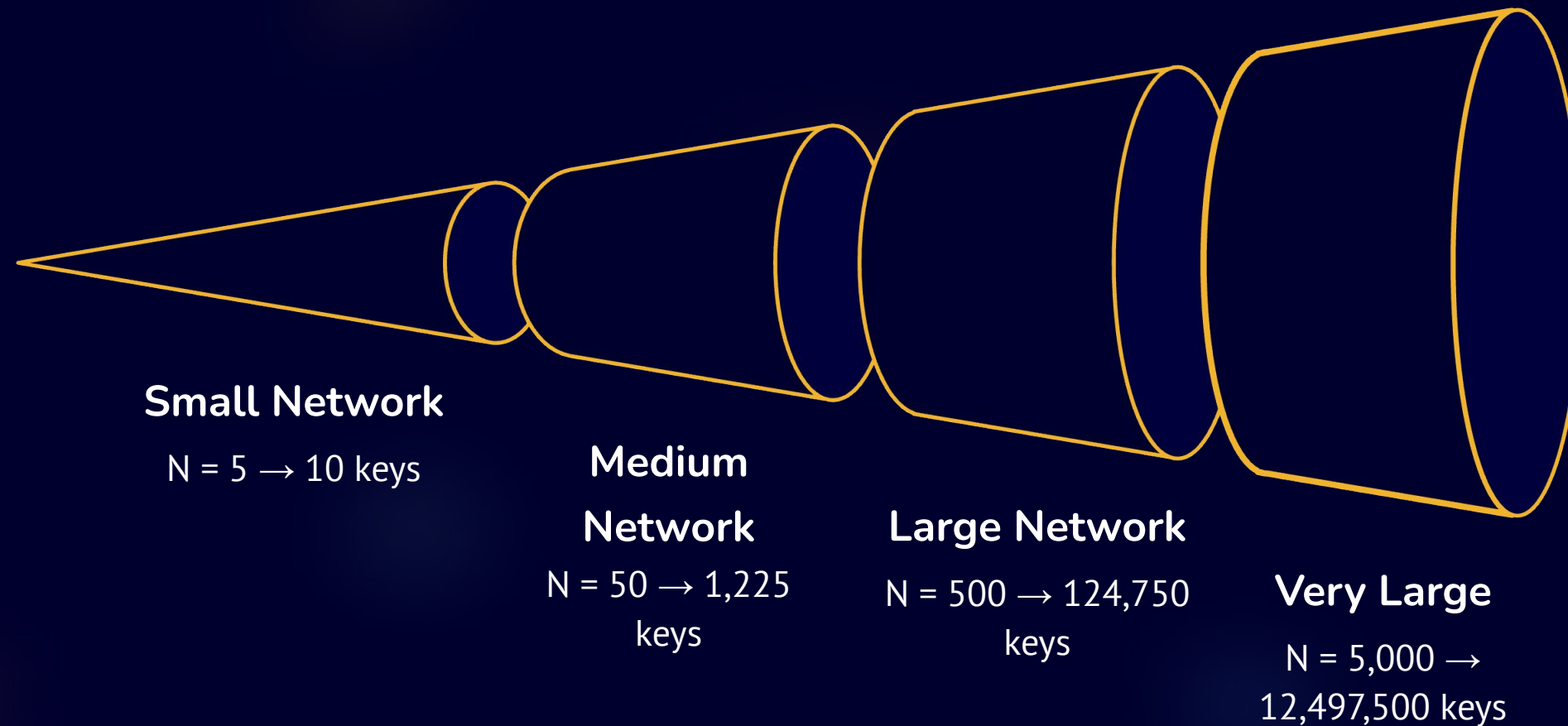
Criptografia Simétrica

Chave única compartilhada
(ex: AES); muito mais rápida,
ideal para sessões longas e
alto volume de autenticações.



2.2 Problema de Escalabilidade de Chaves

Em um sistema com N entidades, seriam necessárias $N(N-1)/2$ chaves para comunicações seguras ponto a ponto - gerenciamento inviável em larga escala.



Resultado: necessidade de modelo que reduza complexidade de gestão de chaves.

2.3 Terceira Parte Confiável (TPP) - KDC

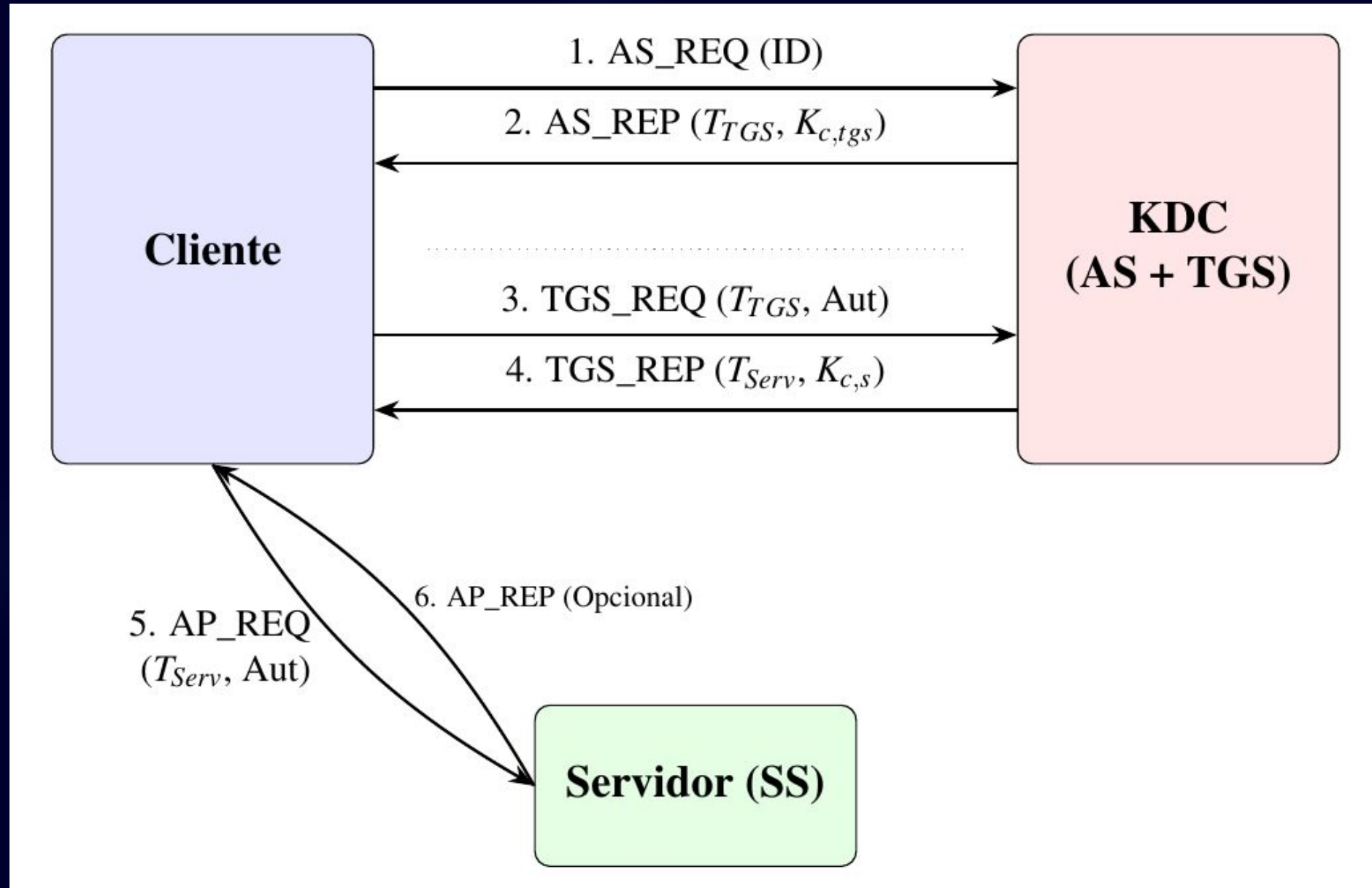


Modelo KDC

Introduz autoridade central (KDC) que emite credenciais temporárias (tickets). Cada entidade precisa apenas de uma chave com o KDC, evitando a complexidade quadrática.

- Centraliza administração
- Minimiza exposição de segredos de longa duração
- Permite escalabilidade prática

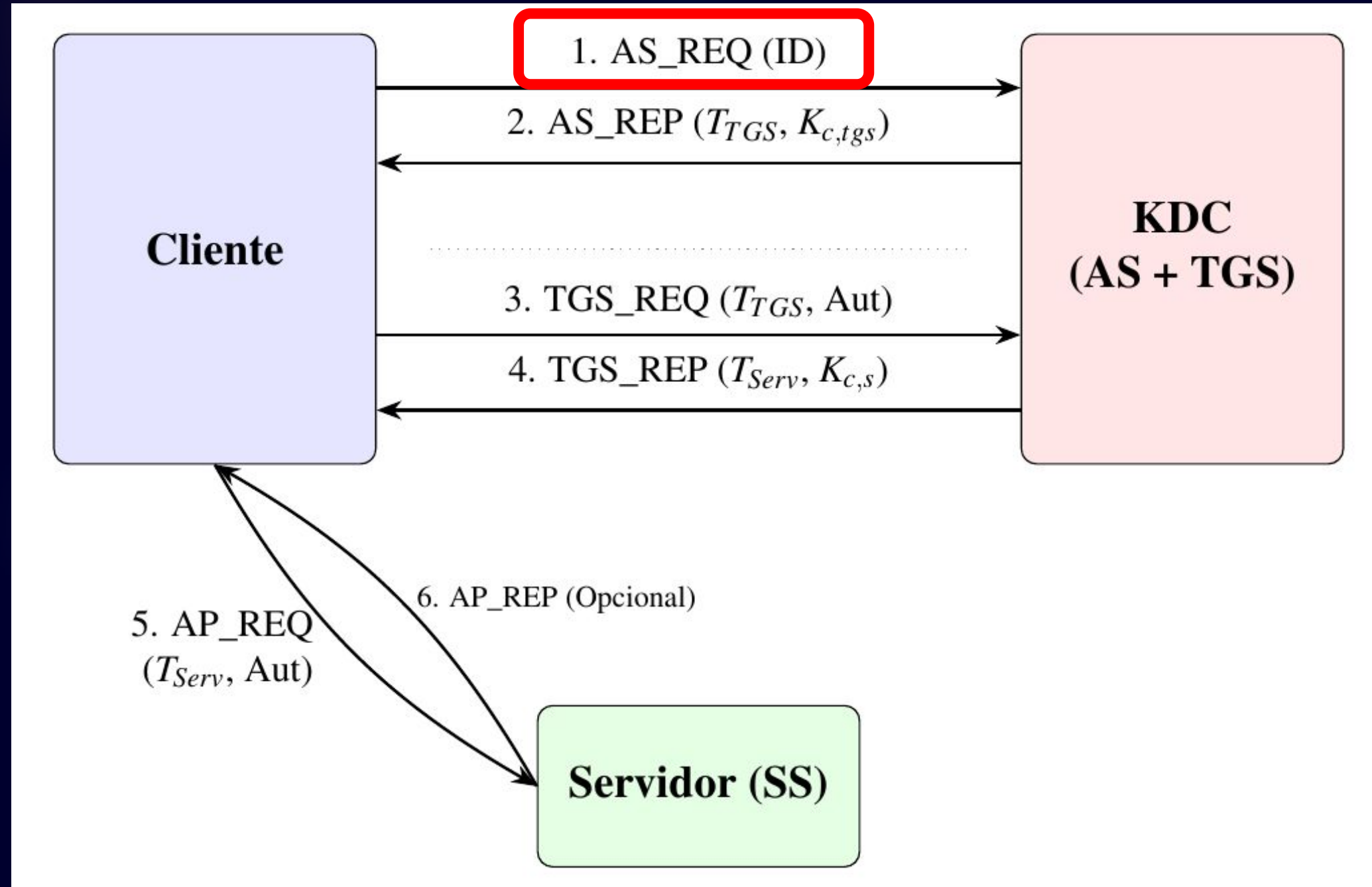
3 O Protocolo Kerberos



3 O Protocolo Kerberos

Cliente 1:

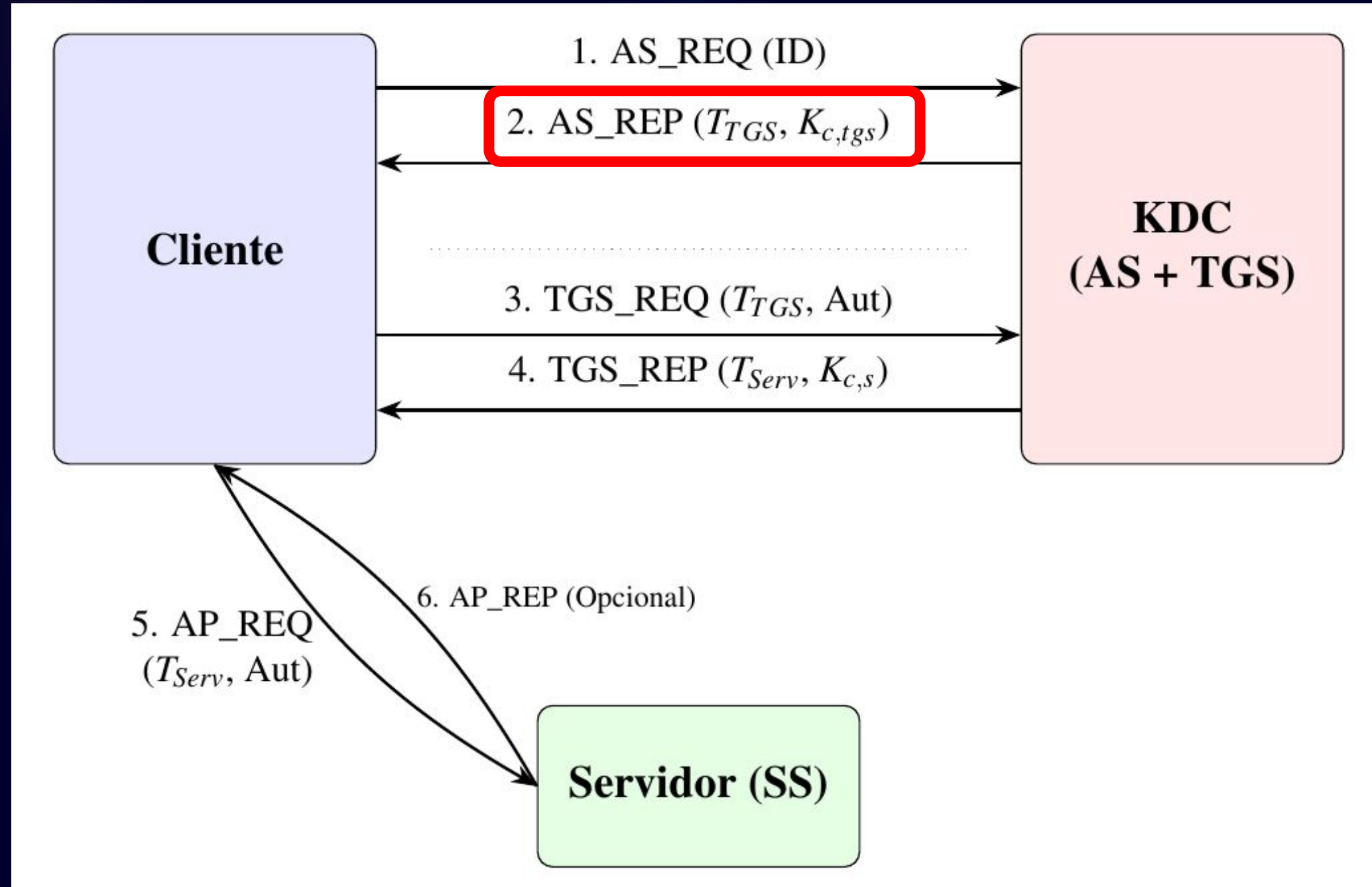
“Eu sou o Cliente 1”



3 O Protocolo Kerberos

KDC:

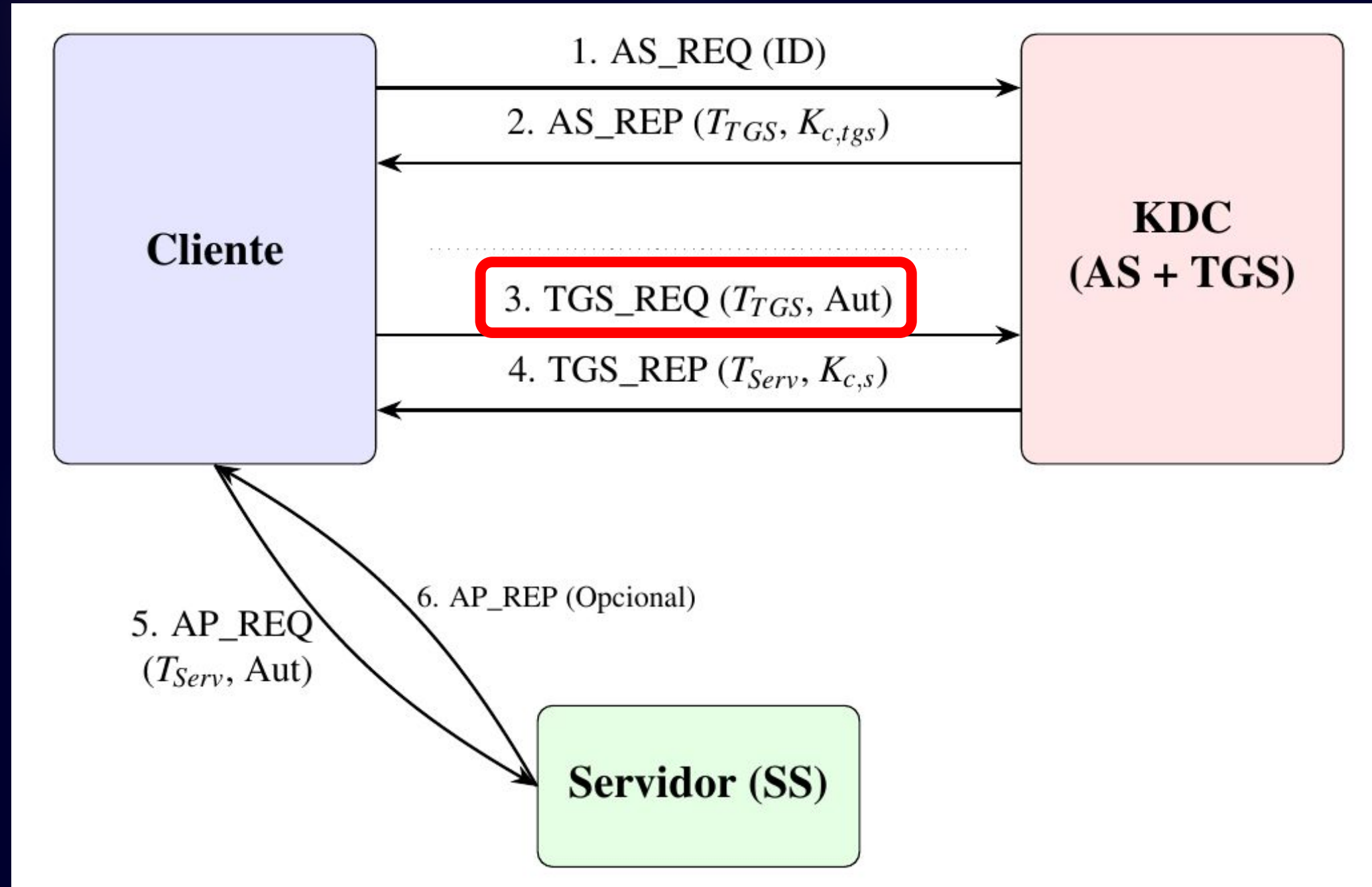
“Eu tenho a chave do cliente 1. Se ele for quem diz ser ele vai conseguir descobrir o a chave de sessão.”



3 O Protocolo Kerberos

Cliente 1:

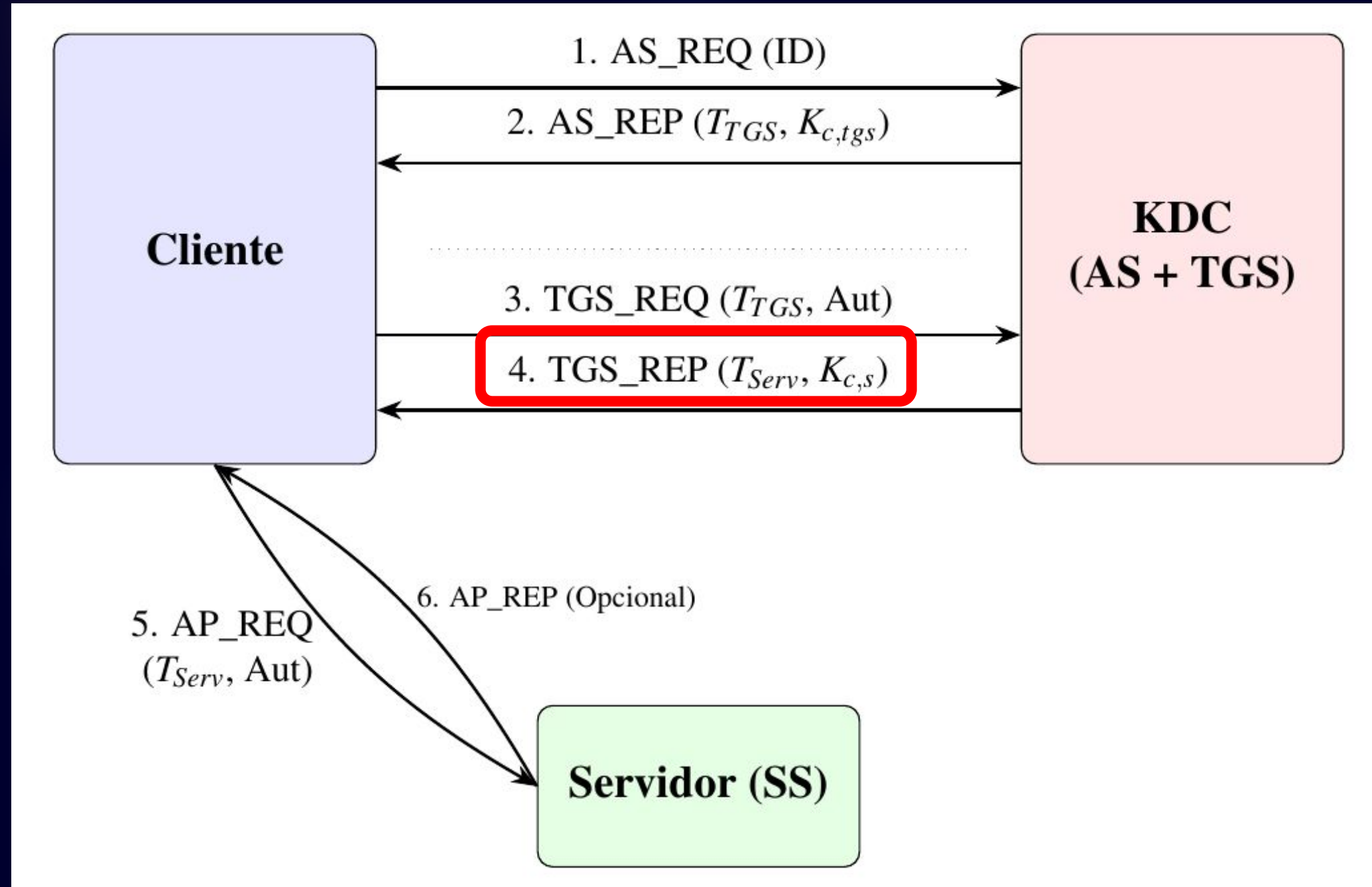
“Escrevi a senha,
agora vou pedir uma
sessão com um
serviço.”



3 O Protocolo Kerberos

KDC:

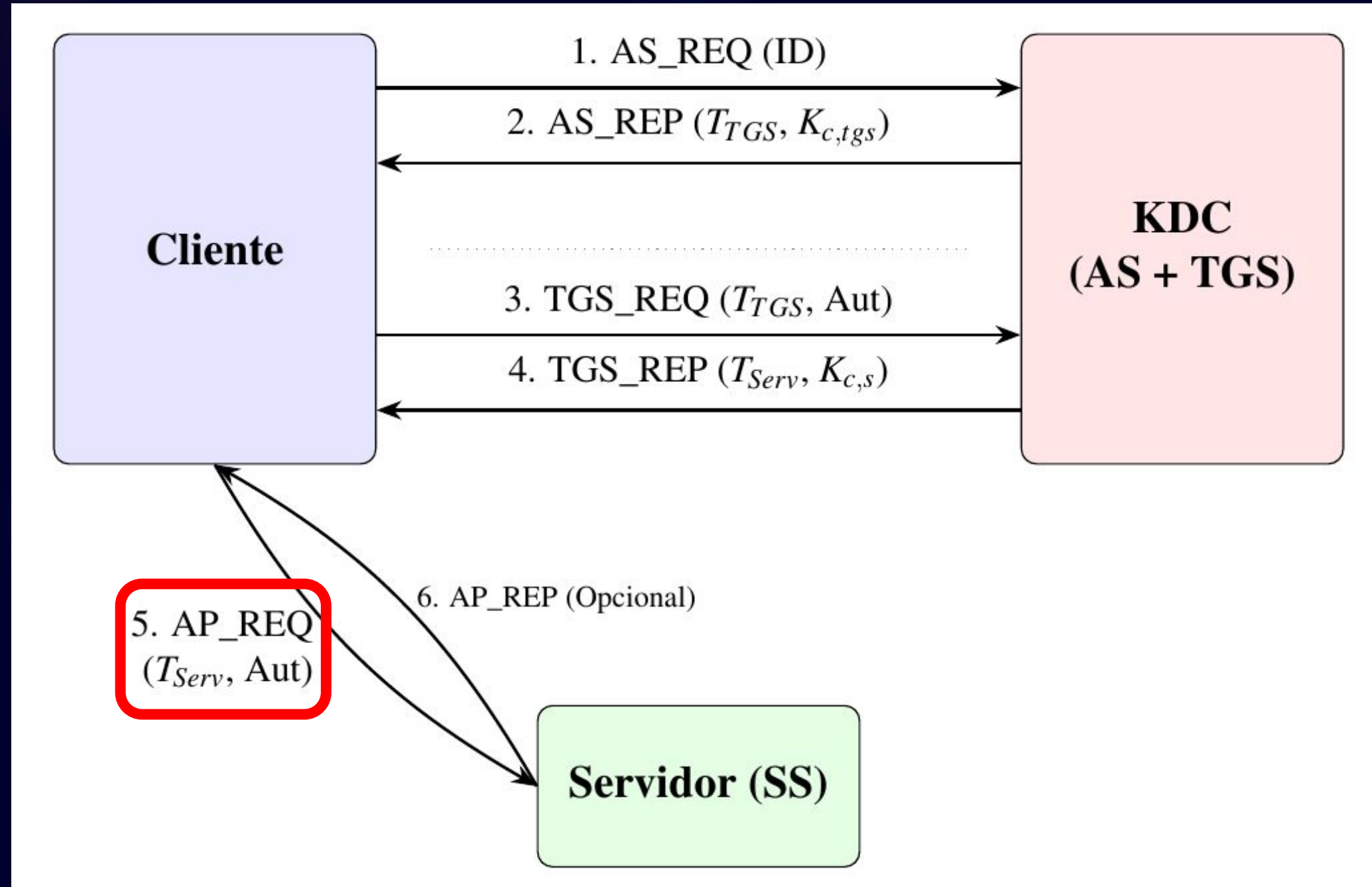
“A chave de sessão do cliente é a mesma que eu escondi no TGT. Agora, pode receber a sessão do serviço.”



3 O Protocolo Kerberos

Cliente 1:

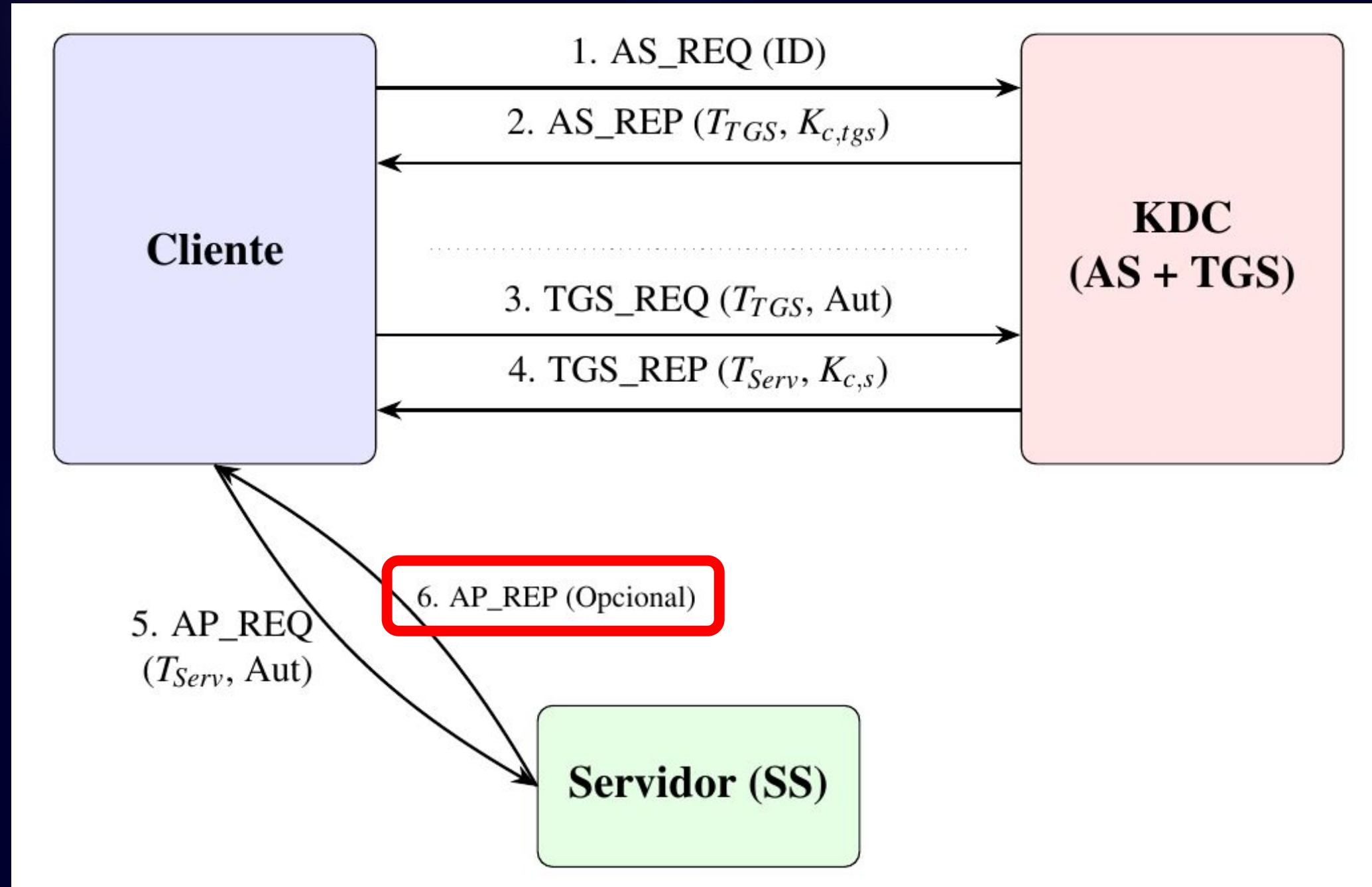
“Servidor, aqui esta a sessão e o Ticket que o KDC me deu. Só você pode ler esse Ticket.”



3 O Protocolo Kerberos

Servidor:

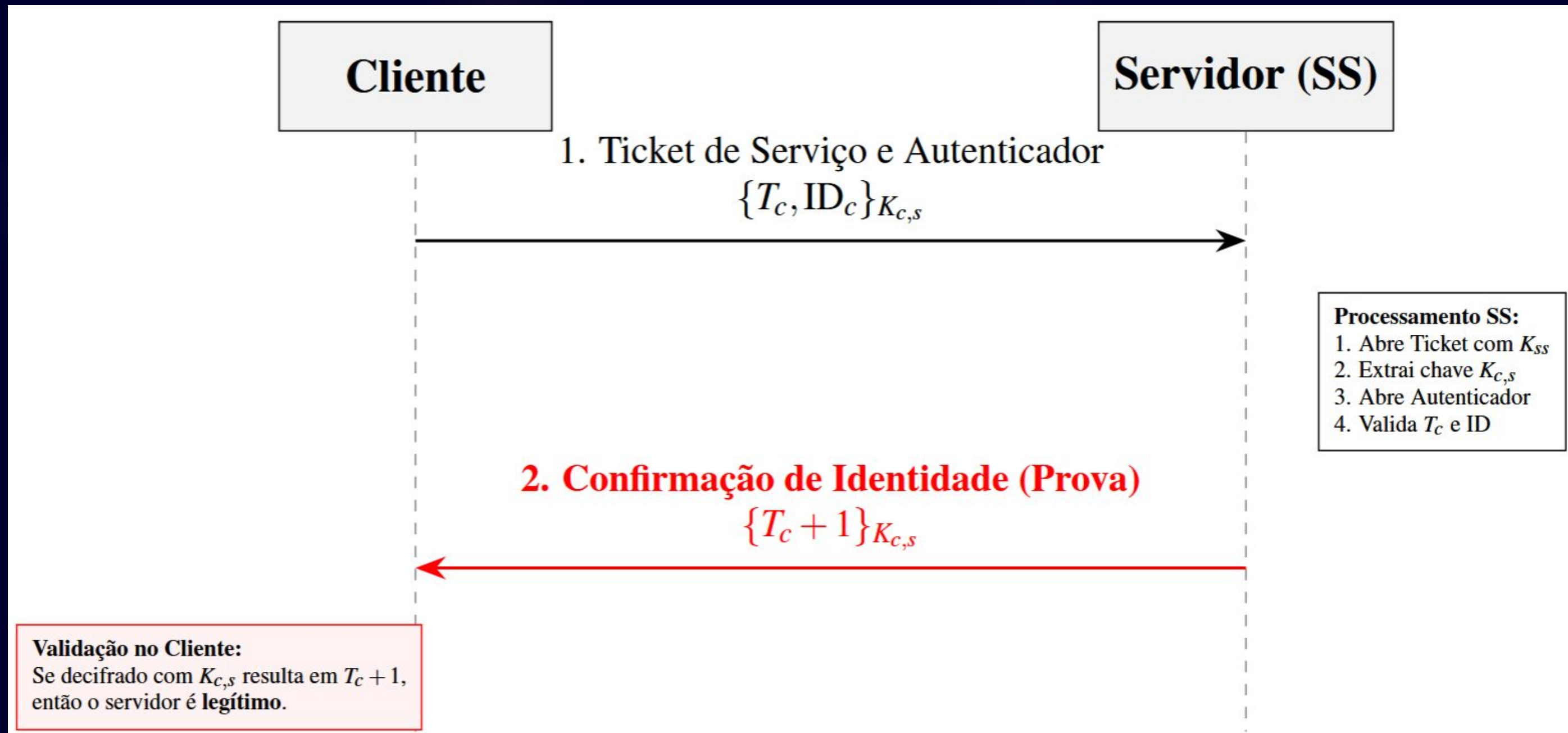
“Eu li o Ticket de
serviço, você ainda
está autenticado pelo
KDC, aqui está o
serviço que você
deseja.”



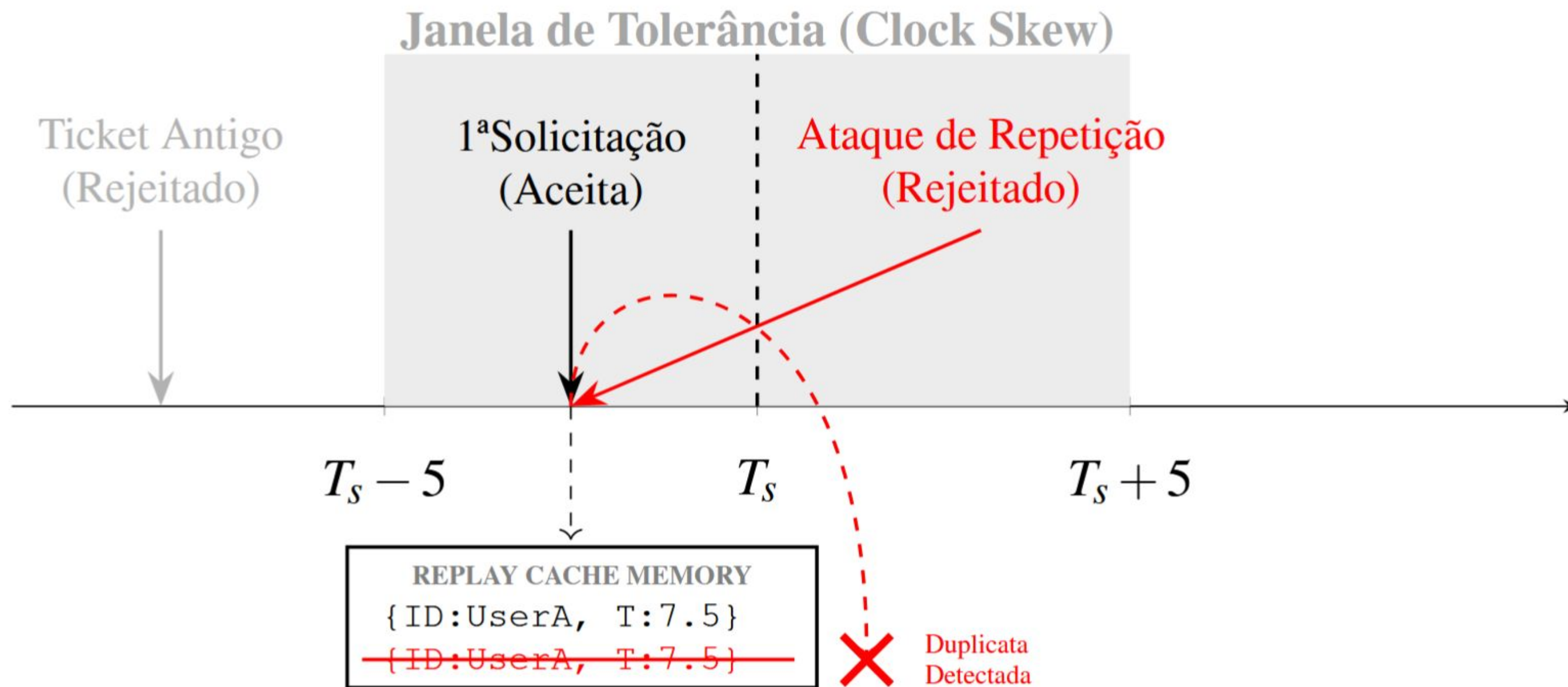
3.4 Mitigação de Ataques

- Authenticators
- Pré-Authentication
- Autenticação Mútua
- Timestamps

Mecanismo de Prevenção de Replay - Replay Cache



Mecanismo de Prevenção de Replay - Replay Cache



Estudo de Caso - Active Directory

- **O Domain Controller (DC) como KDC**
 - **O DC centraliza a função de Key Distribution Center.**
- **Motivo Técnico: O DC hospeda o ntds.dit, banco de dados que contém os hashes de senha (chaves secretas) de toda a floresta.**

Sub-rotinas do Serviço:

Authentication Service (AS): Verifica a identidade inicial.

Ticket Granting Service (TGS): Emite tickets de serviço.



Active Directory Users and Computers

File Action View Help



Active Directory Users and Computers [DC-01.easy365m... ^

- > Saved Queries
- > easy365manager.local
 - > _Admins
 - > _UnSync
 - > BuiltIn
 - > Computers
 - > Domain Controllers
 - > E365M
 - > _Admins
 - > Computers
 - > Contacts
 - > Equipment
 - > Groups
 - > Servers
 - > Users
 - > Australia
 - > Denmark
 - > UnitedStates
 - > ForeignSecurityPrincipals
 - > Managed Service Accounts
 - > Microsoft Exchange Security Groups
 - > NKT_Test
 - > ServiceAccounts

Name

- _Template_Sales
- App Mailbox
- Customer Feedback
- Customer Support
- Hans Christian Ørsted
- Hans Ussing
- Holger Bech Nielsen
- Info Easy365Manager
- Invoices
- Jens Hjorth
- Jens Martin Knudsen
- Lene Hau
- Meeting Room 23
- mortenskrubbeltrang
- Niels Bohr
- Ole Roemer
- Shared Mailbox 10
- Shared Mailbox 11
- Shared Mailbox 12
- Shared Mailbox 13
- Shared Mailbox 14
- Shared Mailbox 15

Hans Christian Ørsted Properties

Member Of Dial-in Environment Sessions
 Remote control Remote Desktop Services Profile COM+
 General Address Account Profile Telephones Organization



Hans Christian Ørsted

First name: Hans Christian Initials:

Last name: Ørsted

Display name: Hans Christian Ørsted

Description:

Office:

Telephone number: Other...

E-mail: hans.c.orsted@easy365manager.com

Web page: Other...

OK

Cancel

Apply

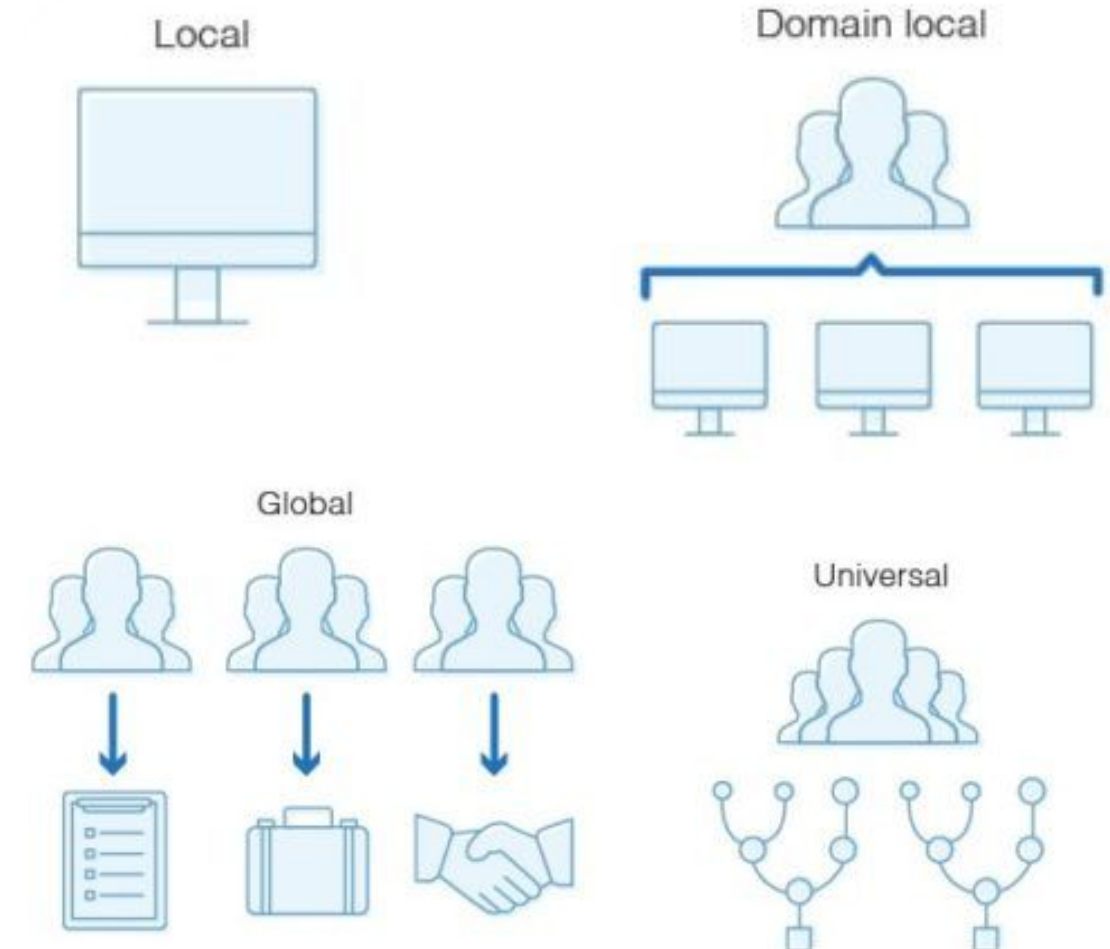
Help

Estudo de Caso - Active Directory

- **A Extensão PAC (Privilege Attribute Certificate)**
 - Diferencial da implementação Microsoft em relação ao Kerberos padrão (MIT).
 - Função: Enquanto o Kerberos autentica (quem é), o PAC autoriza (o que pode fazer).
 - Funcionamento: Insere os SIDs (Security Identifiers) e grupos de segurança dentro do ticket.
- **Benefício: Gestão centralizada de grupos com efeito imediato no acesso às aplicações (Single Sign-On real), sem reconfiguração individual de sistemas**



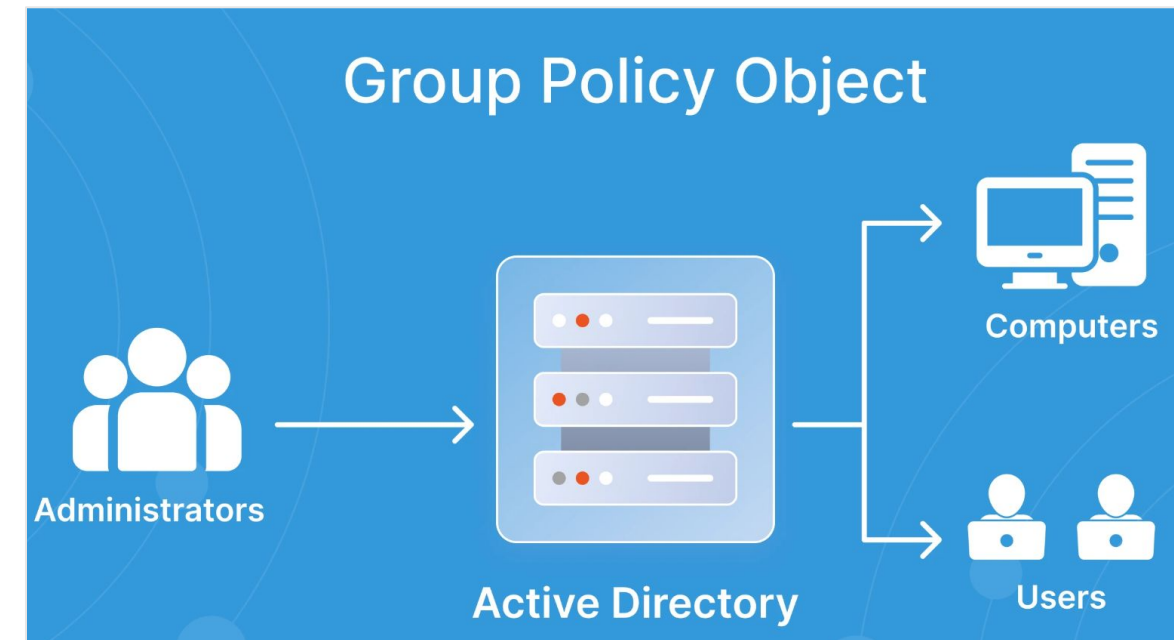
Active Directory Security Group Scope



Estudo de Caso - Active Directory

Gerenciamento via GPO (Group Policy Objects)

- A segurança é dinâmica e configurada via Group Policy Management Console (gpmc.msc).
- Criptografia: Desativação de algoritmos obsoletos (RC4/DES) e imposição de AES-128/256 para mitigar ataques como Kerberoasting.
- Políticas de Ticket: Definição do tempo de vida do TGT (padrão de 10h) e regras de renovação para equilibrar segurança e usabilidade.



Estudo de Caso - Active Directory



Auditoria e Rastreabilidade

- Apenas autenticar não basta; é necessário rastrear a emissão de tickets.
- Monitoramento: Análise de Logs de Eventos (ex: Event ID 4768 para solicitação de TGT).
- Detecção de Ameaças: Identificação de anomalias, como uso de credenciais em horários atípicos ou tentativas de força bruta.

Security Number of events: 168,570

Filtered: Log: Security; Source: ; Event ID: 4624. Number of events: 49,244

Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	4/20/2023 1:43:55 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:42:55 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:42:15 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:41:55 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:41:24 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:41:24 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:40:55 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:40:47 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:40:47 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:40:47 PM	Microsoft W...	4624	Logon
Audit Success	4/20/2023 1:40:47 PM	Microsoft W...	4624	Logon

Event 4624, Microsoft Windows security auditing.

General Details

An account was successfully logged on.

Subject:

Log Name: Security
Source: Microsoft Windows security :
Event ID: 4624
Level: Information
User: N/A

Logged: 4/20/2023 1:43:55 PM
Task Category: Logon
Keywords: Audit Success
Computer: InfoBrasCDV1.com itachouder.com